Android 隐私检测系统
工程实现报告

政策声明 → 多源取证 → 规则判定 → 可追溯报告

李禹江，张博涵，蒋兴宇

我的刀盾队

2026-06-28

目录

1. 系统概述与工程目标
2. 系统架构与数据流
3. 取证层实现
4. 证据模型与判定引擎
5. 工程化与可复现性
6. 审计结果
7. 已知局限与后续工程计划

系统定位

Android 隐私检测系统

一套将**隐私政策承诺**与**多源技术证据**自动比对的审计工具链，面向知情权、同意权、访问权输出结构化、可追溯的审计报告。

- **输入**：隐私政策文本、APK、设备运行时、网络流量、用户数据副本。
- **处理**：声明抽取、静态扫描、动态取证、证据汇聚、规则判定。
- **输出**：三类权利报告，逐条保留证据来源与判定依据。
- **形态**：Python 包 + 统一 CLI + 批量编排，支持增量重跑。

设计目标

1. **证据优先**：每条结论都能追溯到政策原文、静态 API、运行时事件、网络字段或副本文件，不输出无来源的黑盒结论。
2. **规则可复现**：最终 verdict 由规则引擎产生；LLM 只参与路径建议与解释，不参与裁决。
3. **多轨取证**：静态、UI、Frida、mitm 四条轨道按 App 能力自动选择，单轨失败不阻断整体流程。
4. **批量可交付**：多 App 调度、失败重试、断点续跑、日志归档与结构化报告。

工程交付物

子系统	交付物	入口命令
声明抽取	declared_pii、导航路径候选、句级标签	policy_parser
静态取证	static_evidence.json（权限、API、SDK、Tracker）	scan-static
动态取证	dynamic_evidence.json、截图、mitm 流量	capture-dynamic
证据汇聚	evidence/<App>.json（观测集合与 provenance）	build-evidence
权利审计	知情权 / 同意权 / 访问权报告	audit-*
批量编排	job manifest、summary、日志、归档报告	batch、batch-status
法律知识库	法律矩阵、PII 分类与可行证据	kb-build

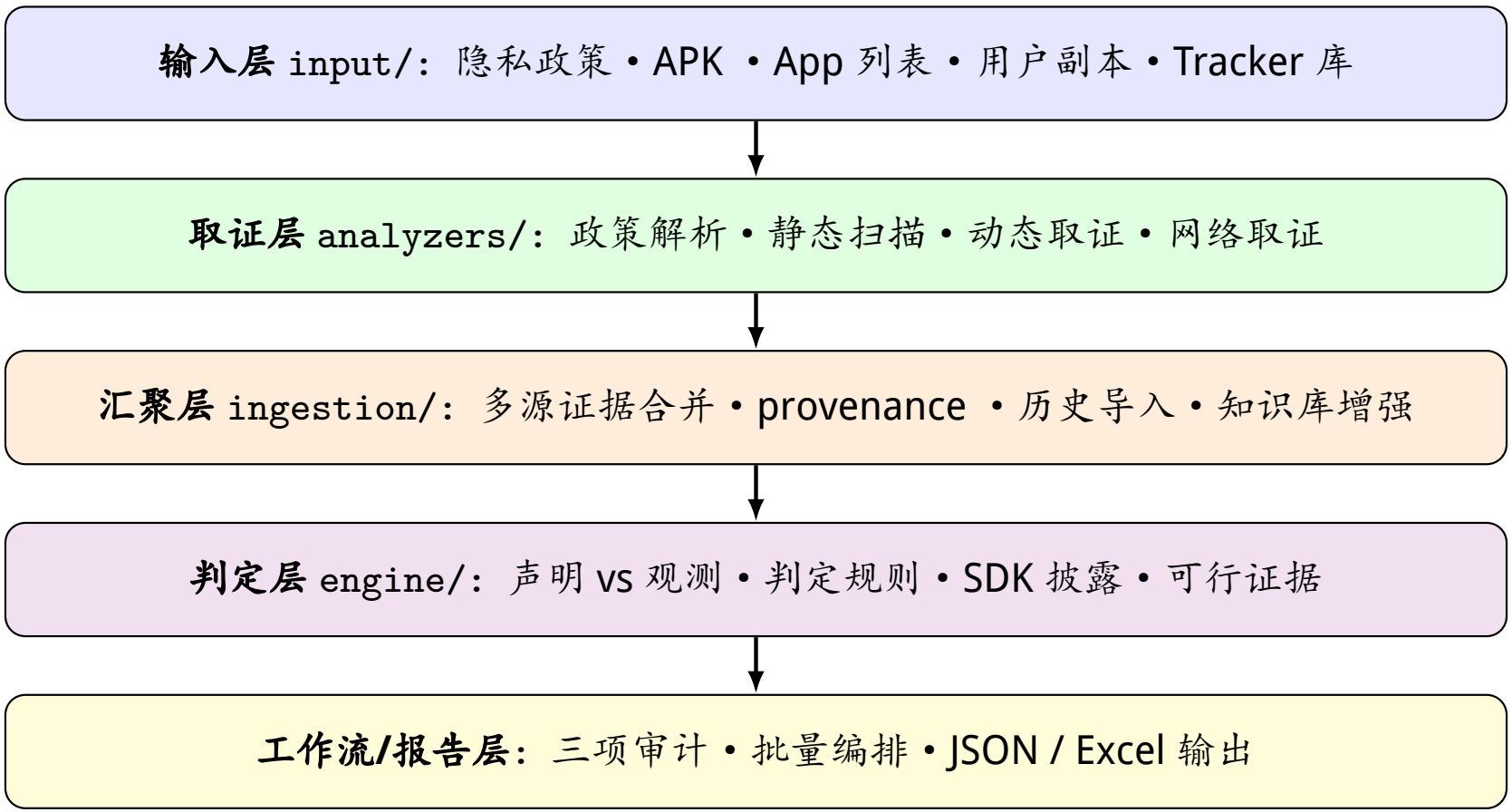
运行环境与技术栈

- **运行环境**：Windows + Python 3.10+，命令统一在 `project/src` 下执行。
- **静态分析**：Androguard（权限、敏感 API、组件）+ Exodus（内嵌 SDK 签名）。
- **设备侧**：MuMu 模拟器/真机，ADB 连接，Appium Server 默认 4723 端口。
- **运行时 Hook**：Frida client 与设备内 frida-server 版本、架构严格匹配。
- **网络观测**：mitmproxy 证书与 ADB 代理，用于 Tracker 与 PII 字段识别。
- **配置驱动**：PII 分类、判定规则、Tracker 库均以 YAML/JSON 独立维护。

评估样本集

- **声明抽取**：23 款 App，覆盖招聘、金融、社交、健康、本地生活等场景。
- **知情权审计**：Keep、小红书、支付宝、LOFTER、智联招聘、世纪佳缘、好大夫医生版、东方财富、小荷健康，共 9 款。
- **同意权 / 访问权审计**：扩展钓鱼人、快看漫画、韭研公社等，形成 15 款 App 的动态验证批次。
- **纳入标准**：政策中存在可执行路径、具备隐私开关或副本入口、能在模拟器/真机完成基本导航。

分层架构


输入层 input/：隐私政策 • APK • App 列表 • 用户副本 • Tracker 库
取证层 analyzers/：政策解析 • 静态扫描 • 动态取证 • 网络取证
汇聚层 ingestion/：多源证据合并 • provenance • 历史导入 • 知识库增强
判定层 engine/：声明 vs 观测 • 判定规则 • SDK 披露 • 可行证据
工作流/报告层：三项审计 • 批量编排 • JSON / Excel 输出

端到端数据流

1. **声明抽取**：policy_parser 将政策文本转为 declared_pii[] 与可执行路径候选。
2. **静态取证**：scan-static 抽取权限、敏感 API、内嵌 SDK 与 Tracker 签名。
3. **动态取证**：capture-dynamic 通过 Appium 导航隐私路径，mitm/Frida 采集运行时与网络证据。
4. **证据汇聚**：build-evidence 统一类型、别名与来源，产出 observed_pii。
5. **规则判定**：engine/compare_engine 生成 verdict 与风险等级。
6. **报告交付**：audit-* 输出单 App 报告，batch 汇总为批次结果。

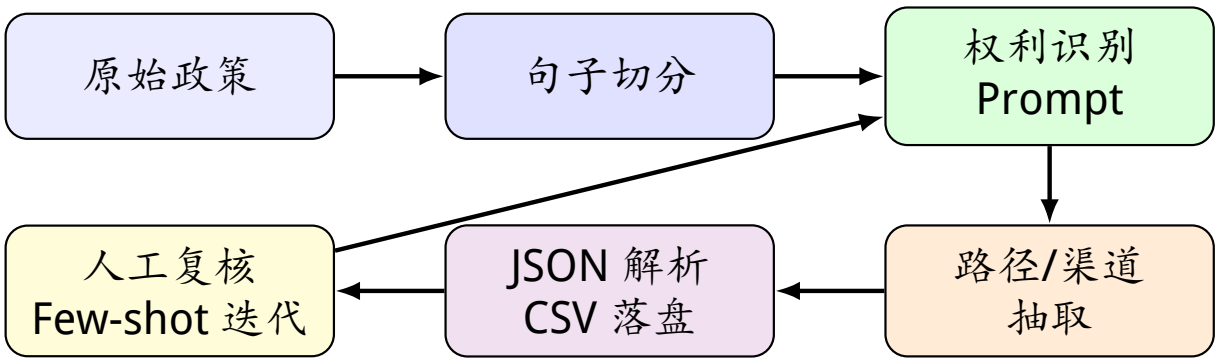
代码结构与模块职责

模块	职责
analyzers/	政策、静态、动态、网络四类原始证据采集
ingestion/	多源证据合并、历史数据导入、知识库增强
engine/	声明与观测的规则比对、verdict 生成
workflows/	单 App 审计、取证流程、批量调度编排
reporting/	JSON / Excel 报告写出
config/	PII 分类、判定规则、标签映射
domain/	EvidenceItem、RightClaim、VerificationResult 等领域模型
utils/	ADB、日志、重试、UI 层级、屏幕抓取等基础设施

统一 CLI 与命令映射

命令	用途
kb-build	由知识库源码生成法律矩阵与 PII 映射 JSON
scan-static	APK 静态扫描：Exodus + Androguard + SDK 签名
capture-dynamic	Appium + Frida + mitm 动态取证
build-evidence	合并静态 / 动态 / 历史证据为扁平证据包
import-legacy	导入历史基线数据，生成派生证据
audit-disclosure	单 App 知情权审计
audit-consent	单 App 同意权审计
audit-access	单 App 访问权审计
batch / batch-status	批量运行与任务状态查询
export-excel	导出 API / 堆栈 / 政策声明对照表

政策声明抽取流水线



复核结果回流到 Prompt，形成可迭代的抽取闭环；句级结果同时作为动态验证的任务来源。

声明抽取的数据契约

- `right_claim`：是否出现权利或知情声明。
- `right_types`：同意、访问复制、删除、注销等枚举标签。
- `method_claim`：是否给出路径、渠道或处理时限。
- `path_text`：最具体的执行路径或联系方式。
- `target_data`：权利指向的数据对象。
- `app_test_candidate`：是否适合后续 UI/网页/人工验证。

契约设计要点

严格区分「有权利声明」与「能否实际操作」：前者进入文本统计，后者才进入动态取证队列。

静态取证实现

- **Exodus**：识别内嵌第三方 SDK 与 Tracker 签名，输出 SDK 清单。
- **Androguard**：解析权限、敏感 API 调用、组件与证书信息。
- **统一结构**：结果归一化为 `static_evidence.json`，供证据包与 SDK 披露比对直接消费。
- **性能策略**：`--fast` 跳过完整 Androguard 分析，用于大批量初筛；深度样本再跑完整模式。
- **工程价值**：无需运行 App 即可给出「具备采集能力」的 S1 级证据。

动态取证流程

1. **解析路径**：政策声明 → `navigation_paths[]`，得到可点击 token 序列。
2. **并行取证**：mitm 抓包、Frida Hook、Appium 真机导航同时运行。
3. **UI 点击**：按 token 序列逐级点击；失败时滚动、侧栏、头像、齿轮、LLM 兜底。
4. **证据落盘**：输出 `dynamic_evidence.json`、`mitm_flows.json`、`network_evidence.json`、截图与 `capture_run.log`。

执行约束

缺少 `--real-run` 时产生的是模拟事件，只能用于流程联调，不得进入同意权对比与审计结论。

Frida 三层 Hook 设计

层次	目标	作用
设备标识层	TelephonyManager 等敏感 API	捕获设备标识读取行为
OkHttp 网络层	请求 URL、header、body	观察 PII 是否进入网络请求
PAPI 目标层	剪贴板、联系人、位置等 API	补充隐私类型的 API 级证据

- 回调经 Reactor 串行化，避免异步消息并发导致证据乱序。
- 支持 spawn / attach 两种注入模式，按 App 行为选择。
- 引入 grace 窗口，覆盖 Application.onCreate 阶段的早期读取。

UI 自动化适配

App	适配要点
世纪佳缘	底部 Tab 文案为 " 我"，需按 bounds 点最右 Tab，避免误点「推荐」。
小荷健康	设置无文字，UserPage 右上角最右侧齿轮为设置，左侧为扫一扫。
支付宝	需精确匹配「我的」，避免宽泛「我」；部分设置入口在 H5/WebView 容器中。
通用策略	政策路径 token + 关键词/头像/齿轮兜底，必要时加入滚动与候选排序。

- 导航桥接记录在 `navigation_bridges.json`，成功路径可复用。
- 每步保留截图与日志，失败时可定位到具体 token 而非整条路径。

多轨取证分工

手段	强项	工程定位
Appium UI	政策路径导航、截图、关键词探测	主轨：驱动到达隐私设置页
mitm 网络	全进程 HTTP 污点、Tracker 识别、开关前后对比	主轨：同意权/访问权核心证据
Frida Hook	API 级采集、调用栈、设备标识精准 Hook	辅助：补 API 证据
静态 + 知识库	APK 信号、法律与 PII 映射推断	知情权多源合并

选型原则

以**覆盖稳定性**而非单点能力选择主轨：网络出口证据受加固影响最小，因此同意权默认 mitm 优先，Frida 作为可选增强。

证据包结构

- `observed_pii`：合并后的观测 PII 类型集合，判定层的唯一输入。
- `sources`：记录每个来源（static / dynamic / legacy / KB）贡献了哪些类型。
- `provenance`：证据文件的落盘路径，支持从报告反查到原始产物。
- `knowledge_base.feasible_evidence`：知识库给出的可引用法律证据。
- `claims.declared_pii`：政策侧声明集合，与观测集合同构、可直接比对。

设计要点

证据包是**扁平、可序列化**的中间层：上游取证可以替换，下游判定与报告无需感知采集实现。

证据强度分级（S0–S5）

级别	含义	典型来源
S0	仅政策文本	政策解析器
S1	具备采集能力	Exodus 权限、Androguard API、内嵌 SDK
S2	用户可触达界面/开关	Appium 步骤、截图、关键词检查
S3	观测到运行时 API 调用	Frida 运行时事件
S4	观测到网络外传	mitm Tracker 域名、`network_keys` 命中
S5	用户访问权产物	用户导出副本

判定门槛：高风险需 S1 + S3 或 S1 + S4；仅 S1 记为「待验证」;「关闭无效」需 S2 确认已关闭且 before/after 均有观测。

三项审计工作流

审计	输入	核心规则
知情权	政策 + 证据包	声明集合 vs 观测集合，按类型输出 verdict
同意权	before / after 动态证据	对比 Tracker 命中与 PII 字段是否仍在传输
访问权	政策 + 运行时 + 用户副本	副本字段与声明/运行时字段求差集

- 三项审计共享同一证据包与 PII 分类体系，避免各自维护字段口径。
- 所有报告保留 `sources[]`，可按来源过滤技术证据与知识库推断。

知情权判定规则

Verdict	含义
consistent	政策声明且多源证据观测到
inconsistent_high_risk	证据观测到，但政策未声明
declared_not_observed	政策声明，但当前证据链未捕获（不等于未采集）

- 比对入口为 engine/compare_engine，规则键为「声明 × 观测」组合。
- 额外输出 sdk_disclosure：政策声明 SDK 与 APK 内嵌 SDK 的差异。
- declared_not_observed 作为证据覆盖缺口处理，不直接给出违规结论。

同意权判定规则

- **采集设计**：同一 App、同一路径，开关开启与关闭各采集一次。
- **主判定**：mitm 流量中的 Tracker 命中、PII 字段与传输条数变化。
- **辅助判定**：Frida 运行时 API 事件在关闭后是否停止。

状态	含义
pass	关闭后相关 Tracker/PII 未继续传输，或流量明显下降
review_needed	关闭后仍有 PII 或 Tracker 命中，需人工确认与开关语义的关联
strong_case	关闭后仍有明确第三方 Tracker 或敏感字段传输

before=0，after=0 属于观测不足，不能据此判定开关有效。

访问权判定规则

- **声明侧**：declared_pii，政策声明用户可查询/复制的字段。
- **运行时侧**：runtime_observed_pii，Frida + mitm 合并的实际字段。
- **副本侧**：copy_covered_pii，用户导出或页面查看的字段。
- **差异输出**：missing_from_copy，运行时存在但副本缺失的字段。

自动化边界

自动匹配只作为提示；manual_copy_audit 输出字段级人工复核建议，最终结论以人工审核为准。

关键工程决策

方面	早期做法	最终实现
判定主体	LLM 直接输出合规结论	规则引擎 + 可追溯证据
证据来源	主要依赖政策文本	政策 / 静态 / 动态 / 历史 / 知识库合并
动态取证	泛化 UI 探索、Frida 单轨	政策路径驱动 + mitm 主轨 + Frida 增强
工程形态	脚本分散、手工串联	统一 CLI、workflow 分层、job id
交付方式	单次运行、人工汇总	batch + manifest + summary

原则：把「结论为什么成立」固化到数据结构和命令流程中，而不是依赖执行者记忆。

批量编排与可复现性

- **job id**：每次批量运行独立编号，产物隔离，支持重复执行与结果对比。
- **manifest + summary**：记录任务状态、成功/失败数、失败原因与报告路径。
- **重试与续跑**：--retry-count 控制失败重试，已完成任务可跳过。
- **日志归档**：单 App 日志、截图、抓包与报告统一落在 job 目录。
- **目录兼容**：新目录优先、旧目录兜底，历史产物可直接复用。

```
python -m privacy_audit.cli batch --apps-file input/apps_audit_batch.txt \
  --mode disclosure --evidence-dir output/evidence \
  --output-dir output/disclosure --job-id batch_005 --retry-count 2
```

配置与扩展点

扩展需求	修改位置
新增 PII 类型	config/personal_info.yaml：别名、权限、API、Hook、网络键
新增判定规则	rules/decision_rules.yaml：按「声明 × 观测」组合配置
新增法律条目	privacy_knowledgebase/input.md，再运行 kb-build
新增取证源	ingestion/evidence_loader.py 的 sources 列表
新增报告格式	reporting/ 增加 writer，并在工作流末尾调用

- 配置与代码分离，新增 App/PII 类型不需要改动判定主流程。
- 领域模型统一在 domain/，避免各模块重复定义字段结构。

可靠性设计与失败处理

- **单轨失败不阻断**：动态采集按可用轨道降级，mitm 与 Frida 互不阻塞。
- **失败可观察**：capture_run.log 记录每步导航与注入结果；batch-status 汇总任务状态。
- **数据可校验**：报告保留 provenance，可反查证据文件是否存在。
- **测试分层**：tests/ 提供单元、集成与端到端测试，覆盖解析、合并与判定主路径。
- **联调隔离**：dry-run 产物与 real-run 产物分离，避免模拟事件污染结论。

声明抽取规模

指标	数量	含义
App 数	23	覆盖招聘、金融、健康、社交等多类应用
政策句子	9639	逐句切分后的分析单元
待复核候选	4371	需模型或人工进一步判断的句子
权利声明正例	5180	命中 right_claim 的句级标签
执行方式正例	1053	命中 method_claim，约 10.9%

Top 应用句级统计

应用	句数	right	method	candidate	method 率
51Job	2674	826	213	207	8.0%
360 借条	697	326	47	47	6.7%
平安证券	608	318	75	75	12.3%
中国工商银行	387	249	35	35	9.0%
好大夫医生版	386	167	26	26	6.7%
智联招聘	372	263	74	74	19.9%
Soul	347	234	42	42	12.1%
58 同城	346	215	46	46	13.3%
合计	**9639**	**5180**	**1053**	**1046**	**10.9%**

结论：权利声明文本充足，但真正给出可执行路径的句子占比明显偏低。

知情权审计结果汇总

Verdict	条数
consistent	90
inconsistent_high_risk	41
declared_not_observed	6

- 9/9 款 App 成功生成报告。
- 一致：声明有，合并证据也有。
- 高风险：证据有，但政策声明不足。
- 未观测：声明有，当前证据链未捕获。

知情权分 App 数据

App	声明	观测	一致	高风险	未观测	
Keep	11	18	11	5	0	
小红书	12	15	10	4	1	
支付宝	11	16	10	5	1	
LOFTER	10	16	10	4	2	
智联招聘	13	17	12	5	0	
世纪佳缘	12	14	10	4	2	
好大夫医生版	11	13	8	4	1	
东方财富	10	16	9	5	2	
小荷健康	11	17	10	5	0	

多数 App 的观测类型数大于声明类型数，差异主要来自静态 SDK、历史基线与知识库推断。

知情权类型并集与交集

	并集（至少 1 款 App 出现）	**交集（9 款 App 均有）**
声明	账号、AndroidID、生物识别、剪贴板、通讯录、身份、IMEI、IP、位置、日志、MAC、未成年人、权限、手机号、画像（15 类）	账号、AndroidID、身份、IMEI、IP、位置、手机号（7 类）
观测	上列 + 权利、SDK、安全（18 类）	AndroidID、通讯录、IMEI、IP、位置、MAC、权限、手机号、画像、权利、安全（11 类）
高风险	剪贴板、通讯录、未成年人、权限、画像、权利、SDK、安全（8 类）	权利、安全（2 类）
未观测	账号、生物识别、剪贴板、日志（4 类）	无

同意权审计结果

- **样本**：15 款 App，全部进入结果分类。
- **pass**：Keep、支付宝、韭研公社。
- **关闭后仍传输**：7 款 App 存在 PII 字段或 Tracker 继续传输。
- **强案例**：钓鱼人、好大夫医生版、快看漫画、世纪佳缘。
- **低流量说明**：支付宝、韭研公社流量极少，pass 结论不宜过度解读。

典型网络对比

App	before 流	after 流	PII 命中	关后仍泄漏
小荷健康	272	312	58→58	无 SDK Tracker；仍有 PII 传输
快看漫画	162	206	21→17	SDK Tracker（Umeng/百度/个推）
世纪佳缘	234	276	38→38	SDK Tracker（百度/Bugly）
钓鱼人	82	83	30→33	SDK Tracker（Umeng/Bugly/百度）
Keep	67	1	4→0	否（pass）

对比口径：同一 App、同一导航路径，仅切换隐私开关状态。

强案例解读

- **钓鱼人**：关闭后 PII 命中从 30 增至 33，仍有 Umeng/Bugly/百度 Tracker。
- **快看漫画**：关闭后流量由 162 升至 206，PII 命中仍为 17，保留多类第三方 Tracker。
- **世纪佳缘**：关闭前后 PII 命中均为 38，百度/Bugly Tracker 仍存在。
- **Keep**：关闭后流量 67→1，PII 命中 4→0，作为开关有效的正向对照。

工程提示

上述差异只能说明「关闭后仍有传输」，是否构成违规还需结合开关语义与字段归属人工确认，因此统一标记为 `review_needed`。

访问权审计结果

App	副本所含个人信息类型
世纪佳缘	生物识别信息、手机号、账号/账户信息、身份信息
小荷健康	手机号、账号/账户信息、身份信息
智联招聘	手机号、身份信息、账号/账户信息、位置信息
支付宝	手机号、身份信息
东方财富	手机号、账号/账户信息、身份信息

- 已完成 5 款 App 的人工副本字段审核，验证了访问权链路可行。
- 副本字段集中于手机号、账号与身份信息，位置与生物识别覆盖较少。
- 剩余样本待导出，taxonomy 别名仍需扩充以提高自动匹配率。

跨模块样本交叉验证

App	知情权	同意权	访问权
Keep	声明 11 / 观测 18 高风险 5	pass，流量 67→1	未审核
世纪佳缘	声明 12 / 观测 14 高风险 4，未观测 2	仍传输，PII 38→38	生物识别、手机号、账号、身份
智联招聘	声明 13 / 观测 17 高风险 5	未纳入动态批次	手机号、身份、账号、位置
支付宝	声明 11 / 观测 16 高风险 5，未观测 1	pass，流量偏低	手机号、身份

同一 App 同时具备知情、同意、访问三类证据时，可形成完整的隐私权利验证链。

已知局限

- **Frida 注入不稳定**：受 spawn/attach 时机、加固、多进程与连接稳定性影响，部分 App 只能拿到 `hook_loaded`，没有有效运行时事件。
- **mitm 覆盖有限**：证书钉扎、私有协议与加密载荷会降低网络证据完整度。
- **UI 路径脆弱**：页面改版、H5/WebView 容器与无障碍文本缺失会导致导航失败。
- **副本采集成本高**：邮箱/异步导出无法被 Hook 直接观测，仍需人工导出与复核。
- **知识库推断需区分**：KB 补充证据应与技术证据分开展示，避免过度归因。

后续工程计划

1. **Frida 加固**：引入 spawn gating 与分层探针，稳定 API 级证据采集。
2. **mitm 增强**：处理证书钉扎、延长低流量窗口、补充 Tracker 规则库。
3. **同意权精化**：将开关语义与字段/Tracker 分类绑定，减少人工解释成本。
4. **访问权补全**：导出剩余 App 副本，扩充字段别名，输出自动覆盖率。
5. **评测体系**：建立人工金标集，分别评估抽取、判定与动态路径的准确性。
6. **交付形态**：完善配置模板与一键批处理，降低新环境部署成本。

结论

- 系统已形成「声明抽取 → 多源取证 → 证据汇聚 → 规则判定 → 报告」的完整工程链路。
- 知情权审计最稳定：9 款 App 批量成功，输出 90 条一致、41 条高风险、6 条未观测。
- 同意权审计以 mitm 为主轨完成 15 款 App 的 before/after 对比，发现 7 款关闭后仍传输，并保留多个强案例。
- 访问权审计完成 5 款 App 的副本人工审核，验证了字段级核对路径。
- 所有结论均保留证据来源与判定规则，具备可复现、可追溯、可增量扩展的工程属性。

谢谢